

Jeremiah Grossman

Venture capitalist (Grossman Ventures <https://grossman.vc>), Internet protector and industry creator. Founded WhiteHat Security & Bit Discovery. BJJ Black Belt.

THURSDAY, JANUARY 17, 2008

The Polls are Open: Top 10 Web Hacks of 2007

Thank you to everyone who helped out with [compiling the list of Web hacking techniques for the last year](#). It took a lot of time and effort scouring the Internet for all the new tricks and reading through the material to understand what was what. I did my best to sanitize the list, find the best references, and remove duplicates (probably still some left). I am confident though that the best of the best are in there to make a meaningful Top Ten for 2007.

There way the [voting process](#) works is each voter get 10 votes to distribute among their favorites. The suggested criteria is cleverness, severity, and overall impact. The polls will close on January 24, at which time the numbers will be tabulated and those with the most votes will rise to the top. With over 80 on the list, surpassing [the number for 2006](#), competition is going to be fierce. [GO VOTE!](#)

The List

[Cross-Site Printing \(Printer Spamming\)](#)
[XSS Vulnerabilities in Common Shockwave Flash Files](#)
[Stealing Pictures with Picasa](#)
[HScan Redux](#)
[ISO-8895-1 Vulnerable in Firefox to Null Injection](#)
[MITM attack to overwrite addons in Firefox](#)
[Microsoft ASP.NET Request Validation Bypass Vulnerability \(POC\)](#)
[Non-Alpha-Non-Digit 3](#)
[Steal History without JavaScript](#)
[Pure Java™, Pure Evil™ Popups](#)
[Google AdSense CSRF hole](#)
[There's an OAK TREE in my blog!?!?!?](#)
[BK for Mayor of Oak Tree View](#)
[Google Docs puts Google Users at Risk](#)
[All Your Google Docs are Belong To US...](#)
[Java Applets and DNS Rebinding](#)
[Scanning internal Lan with PHP remote file opening.](#)
[Firefox File Handling Woes](#)
[Firefoxurl URI Handler Flaw](#)
[Bugs in the Browser: Firefox's DATA URL Scheme Vulnerability](#)
[Multiviews Apache, Accept Requests and free listing](#)
[Optimizing the number of requests in blind SQL injection](#)
[Bursting Performances in Blind SQL Injection - Take 2 \(Bandwidth\)](#)
[Port Scan without JavaScript](#)
[Favorites Gone Wild](#)
[Cross-Browser Proxy Unmasking](#)
[Spoofing Firefox protected objects](#)
[Injecting the script tag into XML](#)
[Login Detection without JavaScript](#)
[Anti-DNS Pinning \(DNS Rebinding \) : Online Demonstration](#)
[Username Enumeration Timing Attacks \(Sensepost\)](#)
[Google GMail E-mail Hijack Technique](#)



BIO

Jeremiah Grossman brings 20+ years of experience in Computer Security and has become one of the most recognizable and world-renowned cybersecurity experts in the industry, coining several of the original hacking terms commonly used around the world today. Early in his career, Jeremiah was known as "The Hacker Yahoo" which led to his role as the company's Information Security Officer. Jeremiah founded WhiteHat Security (now Synopsis), and served as Chief of Security Strategy for SentinelOne which was the highest-valued cybersecurity IPO in history. Most recently, Jeremiah was the founder & CEO of Bit Discovery, which was acquired by Tenable in 2022. He also serves as a company advisor and board member to several tech startups. In his spare time, Jeremiah does Brazilian Jiu-Jitsu and is passionate about classic cars. He recently opened Toybox, a luxury car club in Boise, Idaho.

LINKS

[Jeremiah Grossman](#)

[Twitter](#)

[Facebook](#)

[LinkedIn](#)

[Grossman Ventures](#)

SUBSCRIBE

 Posts

 Comments

Recursive Request DoS
Exaggerating Timing Attack Results Via GET Flooding
Initiating Probes Against Servers Via Other Servers
Effects of DNS Rebinding On IE's Trust Zones
Paper on Hacking Intranets Using Websites (Not Web Browsers)
More Port Scanning - This Time in Flash
HTTP Response Splitting and Data: URI scheme in Firefox
Res:// Protocol Local File Enumeration
Res Timing Attack
IE6.o Protocol Guessing
IE 7 and Firefox Browsers Digest Authentication Request Splitting
Hacking Intranets Via Brute Force
Hiding JS in Valid Images
Internet Archiver Port Scanner
Noisy Decloaking Methods
Code Execution Through Filenames in Uploads
Cross Domain Basic Auth Phishing Tactics
Additional Image Bypass on Windows
Detecting users via Authenticated Redirects
Passing Malicious PHP Through getimagesize()
Turn Any Page Into A Greasemonkey Popup
Enumerate Windows Users In JS
Anti-DNS Pinning (DNS Rebinding) + Socket in FLASH
Iframe HTTP Ping
Read Firefox Settings (PoC)
Stealing Mouse Clicks for Banner Fraud
(Non-Persistent) Untraceable XSS Attacks
Inter Protocol Exploitation
Detecting Default Browser in IE
Bypass port blocking in Firefox, Opera and Konqueror.
LocalRodeo Detection
Image Names Gone Bad
IE Sends Local Addresses in Referer Header
PDF XSS Can Compromise Your Machine
Universal XSS in Adobe's Acrobat Reader Plugin
Firefox Popup Blocker Allows Reading Arbitrary Local Files
IE7.o Detector
overwriting cookies on other people's domains in Firefox.
Embedding SVG That Contains XSS Using Base64 Encoding in Firefox
Firefox Header Redirection JavaScript Execution
More URI Stuff... (IE's Resouce URI)
Hacking without odays: Drive-by Java
Google Urchin password theft madness
Username Enumeration Vulnerabilities
Client-side SQL Injection Attacks
Content-Disposition Hacking
Flash Cookie Object Tracking
Java JAR Attacks and Features
Severe XSS in Google and Others due to the JAR protocol issues
Web Mayhem: Firefox's JAR: Protocol issues (bugzilla)
oDAY: QuickTime pwns Firefox
Exploiting Second Life

Posted by [Jeremiah Grossman](#) at [10:26 AM](#)

6 comments:

Jeremiah Grossman said...



For those interested, here was my personal Top 10. It was kinda difficult to parse through and rank, so many good hacks.

- 1) Universal XSS in Adobe's Acrobat Reader Plugin
- 2) XSS Vulnerabilities in Common Shockwave Flash Files
- 3) Microsoft ASP.NET Request Validation Bypass Vulnerability (POC)
- 4) Google GMail E-mail Hijack Technique

- 5) Port Scan without JavaScript
- 6) Anti-DNS Pinning (DNS Rebinding) : Online Demonstration
- 7) Web Mayhem: Firefox's JAR: Protocol issues (bugzilla)
- 8) Cross-Site Printing (Printer Spamming)
- 9) All Your Google Docs are Belong To US...
- 10) Username Enumeration Timing Attacks (Sensepost)

[January 18, 2008 at 12:45 PM](#)

James Landis said...



Why list 5 hacks using the JAR vuln when they're all the same root cause?

[January 18, 2008 at 2:46 PM](#)

Anonymous said...

This comment has been removed by the author.

[January 18, 2008 at 4:56 PM](#)

Jeremiah Grossman said...



Hey James, thanks for pointing it out. Like I mentioned in the post, in that big of a pool of links it was extremely hard to eliminate all the duplicates. Not to mention find everything. It would have taken me forever to figure out the root cause of each issue, so I just did the best I could with it and posted sooner rather than later. Should there be duplicates, I'll just add them together.

[January 18, 2008 at 4:59 PM](#)

Anonymous said...

Hi Jeremiah,

Regarding "[ASP.NET Request Validation Bypass Vulnerability](#)", the link for the POC is correct, but the advisory points to a much older bypass. Notice that the details provided on both URLs(attack strings) do *NOT* match.

The correct URL for the original advisory, which *includes a POC* anyway is: http://www.procheckup.com/Vulner_PRO7o3.php , as included in [Microsoft's advisory](#).

[January 24, 2008 at 5:34 AM](#)

Jeremiah Grossman said...



@Adrian, thanks for catching that. I got it updated.

[January 24, 2008 at 8:41 AM](#)

[Post a Comment](#)

[Newer Post](#)

[Home](#)

[Older Post](#)

Subscribe to: [Post Comments \(Atom\)](#)

Picture Window theme. Powered by Blogger.

This site uses cookies from Google to deliver its services and to analyse traffic. Your IP address and user agent are shared with Google, together with performance and security metrics, to ensure quality of service, generate usage statistics and to detect and address abuse.

LEARN MORE GOT IT